GIDFINE PHASE 2 SECURITY REVIEW & PHASE 3 READINESS REPORT

Independent Architecture, Authorization, Consent Integrity, and UI Readiness Audit

Repository:	hitracesolutions/loan-engine	**Active Branch:**	development (protected)
HEAD Commit:	afb4323 (verified)	**Spec Reference:**	Gidfine_Dev_Guide.md v1.1
Audit Scope:	Schema, State Machine, Mutations, Queries	**Audit Date:**	October 21, 2026

1. Executive Summary & Audit Verdict

An independent, read-only security audit of the Phase 1 schema, state machine, and Phase 2 Convex mutations was performed. The backend architecture exhibits high structural integrity: caller identities are verified cryptographically via ctx.auth.getUserIdentity(), multi-tenant agency boundaries are strictly maintained, proposal versions are preserved without silent overwrites, borrower PII and agency margins are server-redacted from lender queries, and borrower consent snapshots are secured via SHA-256 fingerprints under Act 843.

Phase 3 Readiness Verdict: CONDITIONAL GO. The backend logic, schema, and guards are fully verified with 16 automated tests. React UI component integration can proceed using typed service adapters, but live browser-to-cloud synchronization is blocked until Matthias provisions Convex Cloud and configures Convex Auth secrets.

2. Audit Findings Ranked by Severity

Severity	Component & Files	Finding & Description	Impact & Required Resolution
HIGH	**Convex Auth Client Setup** frontend/convex/auth.config.ts frontend/src/lib/convex.tsx frontend/package.json	@convex-dev/auth package is not installed; convex.tsx uses standard ConvexProvider rather than ConvexAuthProvider. auth.config.ts uses a placeholder domain.	Blocks live client-side authentication until Matthias provisions the cloud instance, sets JWT secrets, and configures the client provider.
MEDIUM	**Missing List Queries** frontend/convex/loans.ts	loans.ts provides all 5 required mutations and 2 single-item queries, but lacks list queries for borrower loan tracking and agency review inbox.	React dashboards cannot hydrate application lists from Convex. Add getBorrowerApplications and getAgencyReviewQueue in Phase 3.
LOW	**Statutory Legal Clauses** frontend/convex/loans.ts frontend/convex/lib/stateMachine.ts	Consent snapshots cryptographically hash exact financial terms via SHA-256, but formal statutory legal clauses under Act 843 are pending legal counsel.	Does not block backend logic. Supply the legal disclosure clauses for the UI consent modal prior to production release.
INFO	**Pricing Policy Formula** frontend/convex/loans.ts	Rates stored as raw basis points (bps); no interest formula or payment schedule was auto-computed in proposeTerms.	Complies with safety rules. Wire calculation formula once reducing balance vs. flat rate policy is approved.

3. Detailed Security & Architectural Analysis

A. **Authorization & Tenancy Isolation:** Every public mutation and query in loans.ts verifies caller token identity, enforces role restrictions, and asserts actorAgencyId === targetAgencyId. No alternate query or mutation paths exist that bypass these checks.

B. **State-Machine Invariants & Non-Bypass:** Lenders cannot accept loans directly into borrower acceptance or disbursement; agency underwriters must formally approve; borrowers must affirmatively consent before disbursement is permitted; proposal versions are preserved without silent overwriting.

C. **Consent Snapshot Cryptographic Integrity:** computeTermsSnapshotHash deterministically hashes { app, prop, borr, v, pesewas, bps, m, ts } via SHA-256. checkDisbursementReadiness dynamically recomputes and verifies the hash against the recorded snapshot to detect tampering.

D. **Append-Only Audit Trail:** The auditLogs table receives entries for every mutation (APPLICATION_SUBMITTED, PROPOSAL_CREATED, LENDER_PROPOSAL_ACCEPTED/DECLINED, AGENCY_OFFER_APPROVED, BORROWER_CONSENT_RECORDED). No patch or delete operations exist on auditLogs.

E. **Server-Side PII Redaction:** In getLenderProposal, borrower name, email, phone, tokenIdentifier, address, and ID documents are completely stripped on the server. Agency margin is hidden by default. A pseudonymized case ID (APP-XXXXXX) is returned.

F. **Financial Invariants:** All money amounts validated as integer pesewas; all rates validated as integer basis points. Zero floating-point currency representation.

4. Automated Verification Results

Verification Check	Command Line	Result	Actual Execution Summary
State Machine Guard Suite	node --test tests/stateMachine.test.ts	**7/7 PASS**	Linear transitions, assigned lender checks, non-bypass rules, and SHA-256 repeatability verified in 258 ms.
Secure Mutation Suite	node --test tests/mutations.test.ts	**9/9 PASS**	Unauthenticated rejection, role authorization, tenant isolation, version preservation, affirmative consent, PII redaction, and disbursement lockout verified in 485 ms.
Convex TypeScript Checks	npx tsc --noEmit	**PASS (Exit 0)**	0 type errors across Convex schema, state-machine, and loans mutations.
React Production Build	npm run build	**PASS (Exit 0)**	Vite production bundle generated in 10.90s (dist/assets/index-*.js: 343.97 kB).
Python Backend Regressions	pytest tests/ -q	**PASS (6 passed)**	6 passed in 4.48s. Existing comparison and admin endpoints completely intact.

5. Phase 3 UI Integration Roadmap

1. **Service Adapter Layer:** Build typed frontend service interfaces in frontend/src/services/loanService.ts calling loans.ts mutations with graceful fallback.
2. **Application List Queries:** Add getBorrowerApplications and getAgencyReviewQueue in loans.ts to support dashboard views.
3. **Borrower Portal Wiring:** Connect Loan Application Form and Loan Offers / Consent Acceptance modal with affirmative checkbox.
4. **Agency Portal Wiring:** Connect Loan Review Queue, Lender Matching Proposal card, and Agency Approval trigger.
5. **Lender Portal Wiring:** Connect Filtered Proposal Review card (redacted view) and Accept / Decline decision triggers.